



Vulnerability Assessment &  
Penetration Testing (VAPT) Report

Marshan Web8

13 June 2024



---

# TABLE OF CONTENTS

|          |                                               |          |
|----------|-----------------------------------------------|----------|
| <b>1</b> | <b>EXECUTIVE SUMMARY .....</b>                | <b>3</b> |
| <b>2</b> | <b>SCOPE OF TESTING .....</b>                 | <b>3</b> |
| <b>3</b> | <b>METHODOLOGIES USED .....</b>               | <b>3</b> |
| 3.1      | NMAP / ZENMAP.....                            | 3        |
| 3.2      | NESSUS .....                                  | 3        |
| 3.3      | GREENBONE ENTERPRISE .....                    | 4        |
| <b>4</b> | <b>STAY ONE STEP AHEAD OF ATTACKERS .....</b> | <b>4</b> |
| 4.1      | OWASP.....                                    | 5        |
| <b>5</b> | <b>INFRASTRUCTURE .....</b>                   | <b>5</b> |
| 5.1      | 156.38.169.42.....                            | 5        |
| <b>6</b> | <b>REPORTING CONCLUSION .....</b>             | <b>8</b> |
| <b>7</b> | <b>AUDITORS .....</b>                         | <b>8</b> |



## 1 EXECUTIVE SUMMARY

The purpose of this assessment was to point out security loopholes, business logic errors, and missing best security practices. The tests were carried out assuming the identity of an attacker or a malicious user but, no harm was made to the functionality or working of the application / network. A full scan was also performed on the infrastructure to demonstrate a known attack, i.e. someone on the internal network or same public subnetted infrastructure. The scans and brute force were performed over 7 (seven) days, as full and slow comprehensive audits were performed. These types of scans also look at unknown connectivity options, including packet SYN requests.

The overall results will be published below, High-level, Sautech is comfortable and happy with the results. Some recommendations however, is offered and also mentioned throughout this document.

## 2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment. The following scope of servers were covered under the security audit:

- Server hosted at Xneelo - 156.38.169.42

## 3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

### 3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

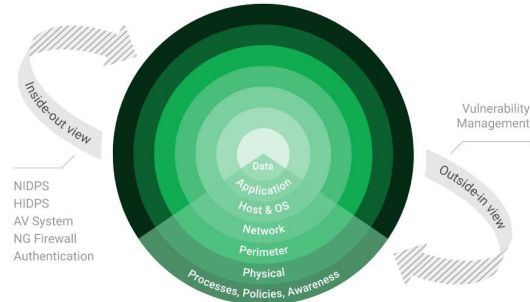
### 3.2 Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.



### 3.3 Greenbone Enterprise

Greenbone is the world's most widely used vulnerability management provider.



## 4 STAY ONE STEP AHEAD OF ATTACKERS

IT security is a process – Open Source vulnerability management provides the foundation. Once you know where the chinks are in your armor, you can do something about them.

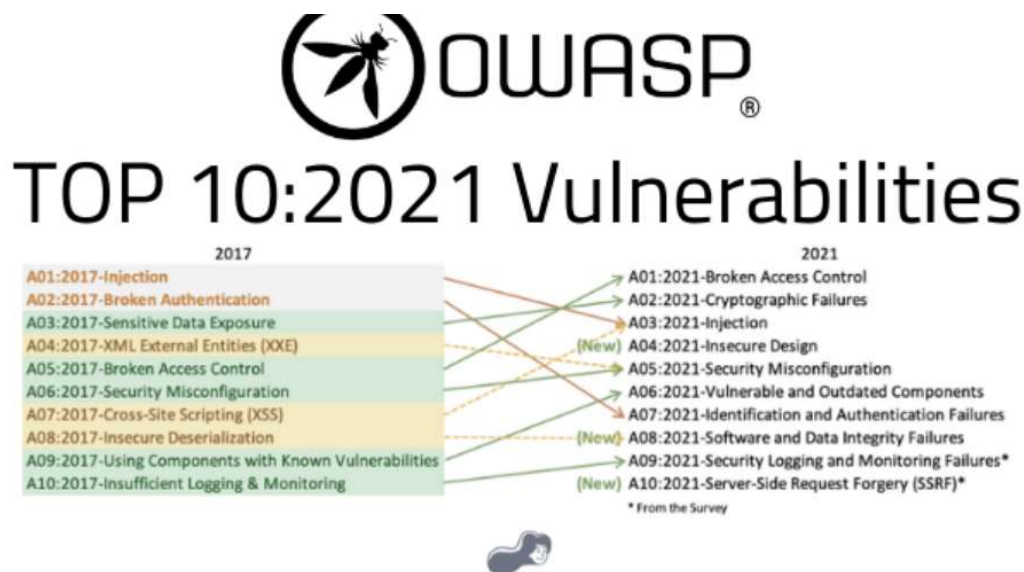


The process – from recognition to remedy and monitoring – represents a continuous cycle. You'll always be one step ahead of attackers.



## 4.1 OWASP

The **Open Web Application Security Project (OWASP)** is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.



## 5 INFRASTRUCTURE

### 5.1 156.38.169.42

We have performed three types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.

#### i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.



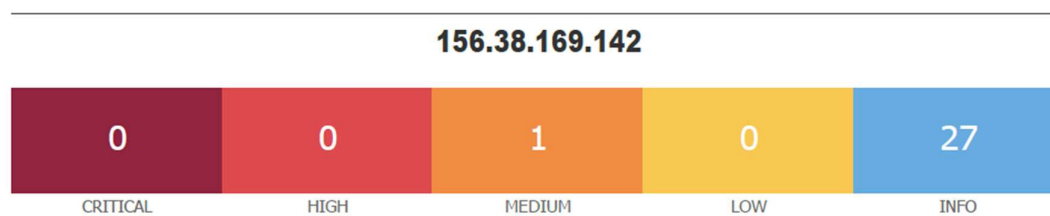
|  | Port | Protocol | State | Service | Version                                 |
|--|------|----------|-------|---------|-----------------------------------------|
|  | 22   | tcp      | open  | ssh     | OpenSSH for_Windows_7.7 (protocol 2.0)  |
|  | 80   | tcp      | open  | http    | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |
|  | 443  | tcp      | open  | http    | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |

Remote Operating System Detection:

- Used Port: 22/tcp (open)
- Used Port: 80/tcp (open)
- Used Port: 443/tcp (open)

## ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:



Vulnerabilities

Total: 28

| SEVERITY | CVSS V3.0 | VPR SCORE | PLUGIN NAME                                                     |
|----------|-----------|-----------|-----------------------------------------------------------------|
| MEDIUM   | 5.9       | 6.7       | 187315 SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795) |
| INFO     | N/A       | -         | 46180 Additional DNS Hostnames                                  |
| INFO     | N/A       | -         | 45590 Common Platform Enumeration (CPE)                         |
| INFO     | N/A       | -         | 54615 Device Type                                               |
| INFO     | N/A       | -         | 84502 HSTS Missing From HTTPS Server                            |
| INFO     | N/A       | -         | 10107 HTTP Server Type and Version                              |
| INFO     | N/A       | -         | 24260 HyperText Transfer Protocol (HTTP) Information            |
| INFO     | 2.1*      | 4.2       | 10114 ICMP Timestamp Request Remote Date Disclosure             |
| INFO     | N/A       | -         | 11219 Nessus SYN scanner                                        |
| INFO     | N/A       | -         | 19506 Nessus Scan Information                                   |
| INFO     | N/A       | -         | 11936 OS Identification                                         |
| INFO     | N/A       | -         | 66334 Patch Report                                              |



|      |     |   |        |                                                          |
|------|-----|---|--------|----------------------------------------------------------|
| INFO | N/A | - | 70657  | SSH Algorithms and Languages Supported                   |
| INFO | N/A | - | 149334 | SSH Password Authentication Accepted                     |
| INFO | N/A | - | 10881  | SSH Protocol Versions Supported                          |
| INFO | N/A | - | 153588 | SSH SHA-1 HMAC Algorithms Enabled                        |
| INFO | N/A | - | 10267  | SSH Server Type and Version Information                  |
| INFO | N/A | - | 56984  | SSL / TLS Versions Supported                             |
| INFO | N/A | - | 10863  | SSL Certificate Information                              |
| INFO | N/A | - | 70544  | SSL Cipher Block Chaining Cipher Suites Supported        |
| INFO | N/A | - | 21643  | SSL Cipher Suites Supported                              |
| INFO | N/A | - | 57041  | SSL Perfect Forward Secrecy Cipher Suites Supported      |
| INFO | N/A | - | 94761  | SSL Root Certification Authority Certificate Information |
| INFO | N/A | - | 156899 | SSL/TLS Recommended Cipher Suites                        |
| INFO | N/A | - | 22964  | Service Detection                                        |
| INFO | N/A | - | 84821  | TLS ALPN Supported Protocol Enumeration                  |
| INFO | N/A | - | 136318 | TLS Version 1.2 Protocol Detection                       |
| INFO | N/A | - | 10287  | Traceroute Information                                   |

\* indicates the v3.0 score was not available; the v2.0 score is shown



## 6 REPORTING CONCLUSION

Based on the OWASP reports it is best to attach these separate to the reporting document. These reports can then be shared with the relevant contractors and/or support personnel to implement the changes and updates.

It is highly recommended to lock down the SSH Ports only to clients whom uses SSH via Source IP's added to Checkpoint Firewall.

Three addendum reports are attached to this report and should be read as one document.

With the following test performed:

- Network scanning
- Knows network attack (from Internet to the FW)
- External HTTP and Port exploits
- Vulnerability assessment on CVE

## 7 AUDITORS

These audits were concluded over a period of 7 (seven) days.  
We hereby confirm that the above information is true and correct:

13<sup>th</sup> June 2024 – Krugersdorp, South Africa

---

Riaan van Jaarsveld  
Security Expert – CCSA / Certified Pen Tester

---

Lukas Janse van Rensburg  
Security Engineer